- 遵循权限最小化原则
- 在pod或container维度设置Security Context
- 使用Pod Security Policy
- 可以开启下列admission controllers：
  - “ImagePoliocyWebhook”：支持对接外部的webhook对部署镜像进行校验
  - “AlwaysPullImages”：在多租环境下防止部署镜像被恶意篡改

Security Context Setting	描述
SecurityContext->runAsNonRoot	声明容器以非root用户运行
SecurityContext->Capabilities	控制容器运行时刻的拥有的系统capabilites，可以显示添加或删除
SecurityContext->readOnlyRootFilesystem	控制容器运行时刻是否有文件系统的写权限
PodSecurityContext-> MustRunAsNonRoot	阻止所有以root用户启动的容器



阿里云 CLOUD NATIVE COMPUTING FOUNDATION

控制面	字段名称
已授权容器的运行	privileged
为容器添加默认的一组能力	defaultAddCapabilities
为容器去掉某些能力	requiredDropCapabilities
容器能够请求添加某些能力	allowedCapabilities
控制卷类型的使用	volumes
主机网络的使用	hostNetwork
主机端口的使用	hostPorts
主机 PID namespace 的使用	hostPID
主机 IPC namespace 的使用	hostIPC
主机路径的使用	allowedHostPaths
容器的 SELinux 上下文	seLinux
用户 ID	runAsUser
配置允许的补充组	supplementalGroups
分配拥有 Pod 数据卷的 FSGroup	fsGroup
必须使用一个只读的 root 文件系统	readOnlyRootFilesystem

- 通过在apiserver的admission-plugin参数中添加PodSecurityPolicy开启
- 在集群中创建指定的PSP策略实例
- 配置策略与身份（user/service account）的RBAC策略绑定，注意大多数pod中使用的身份都是serviceaccount
- 启用PSP后admission会强制要求pod在鉴权后找到至少一个对应的策略实例，因此最好设置一个集群维度的全局策略，同时针对指定namespace配置细化策略
- 注意PSP策略的使用顺序，当同时有多个策略满足权限绑定关系时：
  - 优先使用非mutating，也就是不改变pod模型的策略
  - 如果上述条件过滤后仍旧有多个满足策略，通过策略实例name进行字母排序选取第一个策略进行校验



阿里云 CLOUD NATIVE COMPUTING FOUNDATION